Universidad Técnica Nacional

Ingeniería del Software

Pruebas de Software - ISW-622

Tarea práctica

Creación de Pruebas de Seguridad de Software

Versión 1.0

Repositorio de GitHub:

https://github.com/IvanB012/isw622-pruebas-seguridad.git

Profesor,

Andrés Joseph Jiménez Leandro

Estudiantes,

Iván Barboza Blanco

Ian Angulo Matamoros

Fecha de entrega

30 de Octubre de 2026

Contenido

Fase A - Requisitos, Amenazas y Trazabilidad 4

1. Alcance y resumen 4

2. Inventario de activos y flujo de datos 4

2.1 Activos identificados 4

2.2 Flujo de datos 5

3. Amenazas identificadas 5

4. Requisitos de seguridad verificables 7

5. Criterios de aceptación (Dado–Cuando–Entonces) 8

6. Matriz de trazabilidad requisito–riesgo–caso de prueba 9

Documentación de Fases B y C de Pruebas de Seguridad 10

1. Objeto, alcance y conclusión 10

2. Trazabilidad con requisitos, amenazas y código 11

3. Fase B Diseño de los 12 casos 12

3.1 Registro de gestión QA por caso 16

4. Automatización, integración y estado limpio 17

5. Ciclos rojo verde refactor y correcciones 19

6. Fase C Ejecución manual de API 19

7. Checklist de revisión estática 21

8. Evidencias y transferencia 21

Fase D — Acta de inspección 22

Aspectos conformes verificados 24

Conclusión de la inspección 24

Fase E — Usabilidad y reproducibilidad 25

1. Ejecución de la suite siguiendo únicamente el README 25

2. Análisis de dos situaciones de usabilidad del control 25
3. Ajustes de nombres y mensajes en dos pruebas 26
Fase F — Análisis de resultados y dictamen 27
Estado consolidado de los 12 casos 27
Indicadores 28
Registro de hallazgos 28
Decisión de liberación y limitaciones 31
Anexos 32
Anexo A Scripts detallados de los casos de prueba 32
TC-01 — Lectura del expediente propio por estudiante 32
TC-02 — Acceso horizontal indebido de estudiante 32
TC-03 — Modificación entre sedes por docente 33
TC-04 — Lectura con sesión revocada 34
TC-05 — Límite inferior inválido de nota 35
TC-06 — Lectura con sesión expirada 35
TC-07 — Auditoría sin exposición de token 36
TC-08 — Modificación denegada para administrador 37
TC-09 — Lectura autorizada por docente de su sede 37
TC-10 — Actualización autorizada por docente de su sede 38
TC-11 — Límite inferior válido de nota 39
TC-12 — Límite superior inválido de nota 40
Comandos, versión y resultados de ejecución final 40
Anexo B — Evidencias de las Fases D y E 41
Uso de Inteligencia Artificial: 41

Fase A - Requisitos, Amenazas y Trazabilidad

1. Alcance y resumen

Esta fase corresponde a la Fase A del laboratorio "Creación de Pruebas de Seguridad de Software" (Unidad IV, 25 de 100 puntos). El sistema bajo prueba administra expedientes académicos de dos sedes (UTN Central y UTN Pacífico) con tres roles: estudiante (lee solo su propio expediente), docente (lee y modifica notas únicamente de su sede) y administrador (lee ambas sedes, pero nunca modifica notas). Las sesiones pueden estar activas, revocadas o expiradas, y ninguna sesión inválida debe conceder acceso.

El objetivo de esta fase es identificar los activos en riesgo, describir el flujo de datos del laboratorio provisto (servidor.py + src/lab.py), catalogar las amenazas reales que ya están presentes en el código (marcadas como *todo* en el laboratorio) y traducir esas amenazas en requisitos verificables que Ian usará en la Fase B para diseñar y automatizar los 12 casos de prueba. Esta fase también sienta la base para la Fase F, donde se consolidarán los resultados y se redactará el dictamen de liberación.

2. Inventario de activos y flujo de datos

2.1 Activos identificados

#	Activo	Descripción
A1	Expedientes académicos	Registros por estudiante (id, sede, nota) almacenados en memoria (estado["expedientes"])
A2	Notas	Calificación numérica dentro de cada expediente; su integridad es crítica
A3	Sesiones / tokens	Tokens sintéticos (lab-ana, lab-maria, etc.) que representan autenticación; pueden estar activas, revocadas o expiradas
A4	Permisos y roles	Reglas de autorización por rol (estudiante/docente/administrador) y por sede

A5	Bitácora de auditoría	Lista estado["auditoria"] que registra lecturas y actualizaciones
A6	Servidor/API local	Proceso servidor.py que expone los endpoints HTTP sobre 127.0.0.1:8765

2.2 Flujo de datos

1. Un cliente (curl, PowerShell o Postman) envía una solicitud HTTP a servidor.py, incluyendo un encabezado Authorization: Bearer <token>.
2. ServidorLaboratorio extrae el token y lo pasa a la lógica de negocio en src/lab.py.
3. autenticar() busca el token en estado["sesiones"] y devuelve el usuario asociado (o None).
4. leer_expediente() / actualizar_nota() localizan el expediente en estado["expedientes"] y aplican (o deberían aplicar) las reglas de autorización por rol y por sede.
5. Cada lectura o actualización exitosa se anota en estado["auditoria"], guardando actualmente el **token en texto claro** (riesgo de confidencialidad, ver Amenaza T5).
6. El servidor serializa la respuesta en JSON y la devuelve con el código HTTP correspondiente (200/400/401/403/404).

Todo el estado vive en memoria (ServidorLaboratorio.estado) y se reinicia solo al reiniciar el proceso o, en las pruebas unittest, al llamar estado_inicial() en cada setUp.

3. Amenazas identificadas

ID	Actor	Acción abusiva	Activo afectado	Impacto	Prioridad	Evidencia en el código
T1	Estudiante autenticado (ej. Ana)	Solicita el expediente de otro estudiante	A1, A2	Alto — expone nota y datos	Alta	leer_expediente() no verifica que el expediente pedido sea

		(acceso horizontal indebido)		de otra persona		el propio (TODO SEC-01)
T2	Docente autenticado (ej. María)	Actualiza la nota de un expediente de otra sede	A2	Alto — corrompe una calificación oficial fuera de su jurisdicción	Alta	actualizar_nota() solo valida rol == "docente", no compara sedes (TODO SEC-02)
T3	Usuario con sesión revocada o expirada (ej. lab-vencida)	Repite una lectura o actualización después de que su sesión debería estar inválida	A3, A1, A2	Alto — anula por completo el control de acceso	Alta	autenticar() ignora los campos revocada y expirada de la sesión (TODO SEC-03)
T4	Docente (por error o intención)	Envía una nota fuera del rango [0,100] (p. ej. 150 o -5)	A2	Medio — corrompe datos académicos y puede afectar cálculos posteriores	Media	actualizar_nota() solo valida el tipo numérico, no el rango (TODO SEC-04)
T5	Cualquiera con acceso a la bitácora	Lee estado["auditoria"] y obtiene tokens de sesión en texto claro	A3, A5	Medio-Alto — permite secuestro de sesión si la bitácora se filtra	Media	leer_expediente() / actualizar_nota() guardan "token": token sin enmascarar
T6	Atacante externo	Prueba tokens al azar contra	A1, A3	Medio — facilita	Media	El servidor no implementa límite de

		/expedientes/{id} repetidamente		adivinar sesiones válidas		intentos ni bloqueo por fuerza bruta

4. Requisitos de seguridad verificables

ID	Categoría	Requisito
SEC-01	Confidencialidad / autorización horizontal	Si un estudiante solicita el expediente de otra persona, el servicio debe denegar la lectura (403), no incluir la nota en la respuesta y no modificar los registros.
SEC-02	Autorización (sede)	Si un docente intenta modificar la nota de un expediente que no pertenece a su sede, el servicio debe denegar la operación (403) y la nota original debe permanecer sin cambios.
SEC-03	Sesiones	Si una sesión está revocada o expirada, cualquier solicitud de lectura o modificación con ese token debe ser rechazada (401), sin importar el rol del usuario.
SEC-04	Validación	Si se intenta actualizar una nota con un valor fuera del

		rango [0,100] o de tipo no numérico, el servicio debe rechazar la solicitud (400).
SEC-05	Integridad	Cuando una actualización es rechazada por cualquier motivo (autorización, sesión o validación), la nota original del expediente debe permanecer exactamente igual antes y después del intento.
SEC-06	Trazabilidad	La bitácora de auditoría debe registrar cada lectura y actualización con acción, expediente y marca de tiempo, sin almacenar el token de sesión en texto claro.
SEC-07	Autorización (rol)	Un administrador puede leer expedientes de ambas sedes, pero cualquier intento de modificación de nota por su parte debe ser denegado (403).

Estos requisitos cubren las seis categorías pedidas por la rúbrica: confidencialidad (SEC-01), autorización (SEC-02, SEC-07), integridad (SEC-05), sesiones (SEC-03), validación (SEC-04) y trazabilidad (SEC-06).

5. Criterios de aceptación (Dado–Cuando–Entonces)

- **AC-01 (SEC-01):** Dado que Ana (estudiante, expediente 101) tiene una sesión válida, Cuando solicita el expediente 202 (de Luis), Entonces el servicio responde

403, no incluye el campo nota en la respuesta, y el expediente 202 permanece sin cambios.

- **AC-02 (SEC-02):** Dado que María (docente de Central) tiene una sesión válida, Cuando intenta actualizar la nota del expediente 202 (sede Pacífico), Entonces el servicio responde 403 y la nota original de 202 permanece intacta.
- **AC-03 (SEC-03):** Dado que la sesión de Ana fue revocada mediante /sesiones/revocar, Cuando Ana intenta leer el expediente 101 con ese mismo token, Entonces el servicio responde 401 y no incluye ningún dato del expediente.
- **AC-04 (SEC-04/SEC-05):** Dado que María tiene sesión válida y el expediente 101 existe con nota 82, Cuando envía una nota de 150 para actualizar el expediente 101, Entonces el servicio responde 400 y la nota de 101 permanece en 82.

6. Matriz de trazabilidad requisito–riesgo–caso de prueba

Requisito (SEC)	Riesgo (amenaza)	Caso de prueba (preliminar)	Evidencia esperada
SEC-01	T1 — acceso horizontal indebido	TC-01 (positivo: lee lo propio) / TC-02 (negativo: lee ajeno)	TC-01: 200 con datos propios. TC-02: 403, sin campo nota en la respuesta.
SEC-02	T2 — acceso indebido entre sedes	TC-03	403; nota del expediente 202 idéntica antes y después del intento.
SEC-03	T3 — sesión revocada/expirada ignorada	TC-04	401 tras revocar/expirar la sesión; sin datos del expediente en la respuesta.
SEC-04	T4 — valores fuera de rango aceptados	TC-05	400; tipo/rango rechazado.

SEC-05	T4 (y T1–T3 por extensión)	TC-06 *(por diseñar con Ian)*	Comparación de la nota antes/después de cada intento rechazado — debe quedar intacta.
SEC-06	T5 — fuga de token en la bitácora	TC-07 *(por diseñar con Ian)*	Inspección de estado["auditoria"] tras varias operaciones: ninguna entrada debe mostrar el token en texto claro.
SEC-07	— (control de rol administrador)	TC-08 *(por diseñar con Ian)*	403 al intentar POST /expedientes/{id}/nota con el token lab-admin.
—	T6 — fuerza bruta de tokens	*(hallazgo para Fase F, no necesariamente un caso TDD)*	Registro de múltiples intentos fallidos sin bloqueo observado.

Documentación de Fases B y C de Pruebas de Seguridad

1. Objeto, alcance y conclusión

Este documento registra el trabajo de aseguramiento de calidad realizado por Ian en las Fases B y C del laboratorio autorizado laboratorio_seguridad. El alcance comprende el diseño de 12 casos de prueba, automatización, ciclos TDD, pruebas manuales de API, revisión estática, correcciones y regresión. Las pruebas usan únicamente datos sintéticos y el servicio local 127.0.0.1:8765.

La ejecución final cubre los 12 casos diseñados mediante 12 pruebas unitarias y 2 pruebas de integración HTTP, para un total de 14 pruebas aprobadas. T6 permanece como riesgo residual fuera del alcance de corrección del laboratorio.

2. Trazabilidad con requisitos, amenazas y código

Control	Amenaza	Regla verificable de Fase A	Implementación y pruebas
SEC-01	T1	Estudiante solo consulta su expediente; lectura ajena 403 sin nota.	leer_expediente; TC-01/TC-02; TDD 01.
SEC-02	T2	Docente solo modifica notas de su sede; rechazo 403 sin cambio.	actualizar_nota compara sede; TC-03/TC-09/TC-10.
SEC-03	T3	Sesión revocada o expirada responde 401 sin datos.	autenticar; TC-04/TC-06; TDD 02.
SEC-04	T4	Nota debe ser numérica y estar entre 0 y 100; rechazo 400.	actualizar_nota; TC-05/TC-11/TC-12 y PM-01.
SEC-05	T2/T4	Toda actualización rechazada mantiene la nota original.	Aserciones antes/después; TC-03/TC-05/TC-08.
SEC-06	T5	Auditoría registra acción, expediente y tiempo sin token.	registrar_auditoria; TC-07.

SEC-07	Rol	Administrador lee, pero no modifica notas.	actualizar_nota; TC-08.
Residual	T6	No existe limitación de intentos de token.	Registrar en Fase F; no se afirma corrección.

3. Fase B Diseño de los 12 casos

La clasificación cumple 3 positivos, 6 negativos y 3 de frontera. Cada caso conserva requisito, precondiciones, entrada/pasos, oráculo y evidencia. El estado refleja la ejecución real de la Fase C.

TC-01 Positivo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-01/T1	Estado inicial; lab-ana válido; expediente 101 es de Ana.	GET /expedientes/101 con Bearer lab-ana.	200; datos de Ana y nota propia; sin cambios.	Unitaria; aprobado.

TC-09 Positivo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-02	Estado inicial; lab-maria; 101 de Central.	GET /expedientes/101 con Bearer lab-maria.	200; lectura autorizada por sede.	Aprobado; evidencia en tc-09-docente-misma-sede.

TC-10 Positivo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-02/05	Estado inicial; lab-maria; 101 nota 82.	POST /expedientes/101/nota con {"nota":85}.	200; nota 85 persistida; otros expedientes sin cambio.	Unitaria; aprobado.

TC-02 Negativo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-01/T1	Estado inicial; lab-ana; 202 es de Luis.	GET /expedientes/202 con Bearer lab-ana.	403; sin nota ni datos de Luis; sin cambio.	TDD 01; aprobado.

TC-03 Negativo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-02/05/T2	Estado inicial; lab-maria; 202 Pacífico nota 91.	POST /expedientes/202/nota con {"nota":85}.	403; nota 202 conserva 91.	Unidad, integración y Postman; aprobado.

TC-04 Negativo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-03/T3	Estado inicial; lab-ana válida; 101 disponible.	Revocar lab-ana; luego GET /expedientes/101.	200 al revocar; 401 posterior sin datos.	TDD 02 y Postman; aprobado.

TC-06 Negativo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-03/T3	Estado inicial; lab-vencida expirada; 101 disponible.	GET /expedientes/101 con Bearer lab-vencida.	401; sin nota ni datos.	Unitaria; aprobado.

TC-07 Negativo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-06/T5	Estado inicial; operación autorizada y acceso de prueba a auditoría.	Leer 101; inspeccionar última entrada.	Acción, actor, id, timestamp; ningún token.	TDD 04; aprobado.

TC-08 Negativo

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-07/05	Estado inicial; lab-admin; 101 nota 82.	POST /expedientes/101/nota con {"nota":90}.	403; nota conserva 82.	Unitaria; aprobado.

TC-05 Frontera

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-04/05/T4	Estado inicial; lab-maria; 101 nota 82.	POST /expedientes/101/nota con {"nota":-1}.	400; nota conserva 82.	Unidad, integración y Postman; aprobado.

TC-11 Frontera

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-04	Estado inicial; lab-maria; 101 Central.	POST /expedientes/101/nota con {"nota":0}.	200; nota 0 persistida.	Aprobado; evidencia en tc-11-limite-inferior-valido.

TC-12 Frontera

Requisito y amenaza	Precondiciones	Entradas y pasos	Resultado esperado u oráculo	Evidencia y estado
SEC-04/05/T4	Estado inicial; lab-maria; 101 nota 82.	POST /expedientes/101/nota con {"nota":101}.	400; nota conserva 82.	Aprobado; evidencia en tc-12-limite-superior-invalido.

3.1 Registro de gestión QA por caso

Se incorporan los campos de control de ejecución solicitados por la plantilla de script de prueba. No se utiliza relación con casos de uso porque el laboratorio no define casos de uso formales; la trazabilidad operativa se conserva mediante SEC, amenaza, caso y evidencia.

Caso	Estado	Resultado obtenido	Defecto o comentario	Diseño	Ejecución
TC-01	Aprobado	200; Ana consulta 101.	Sin defecto.	Ian	Ian
TC-09	Aprobado	Ejecución aislada OK.	Sin defecto.	Ian	Ian
TC-10	Aprobado	200; nota 85 persistida.	Sin defecto.	Ian	Ian
TC-02	Aprobado	403; sin nota de Luis.	B-DEF-01 corregido: acceso horizontal devolvía 200.	Ivan	Ivan
TC-03	Aprobado	403; nota 202 intacta.	B-DEF-03 corregido:	Ivan	Ivan

			modificación entre sedes devolvía 200.		
TC-04	Aprobado	200 revocar; 401 lectura posterior.	B-DEF-02 corregido: sesión revocada devolvía 200.	Ivan	Ivan
TC-06	Aprobado	401; sin datos.	Sin defecto adicional.	Ivan	Ivan
TC-07	Aprobado	Actor y timestamp presentes; token ausente.	C-DEF-01 corregido: auditoría incompleta y exposición de token.	Ian	Ian
TC-08	Aprobado	403; nota intacta.	Sin defecto.	Ivan	Ivan
TC-05	Aprobado	400; nota intacta.	B-DEF-04 corregido: -1 era aceptado.	Ian	Ian
TC-11	Aprobado	Ejecución aislada OK.	Sin defecto.	Ian	Ian
TC-12	Aprobado	Ejecución aislada OK.	Sin defecto.	Ivan	Ivan

4. Automatización, integración y estado limpio

tests/test_laboratorio.py contiene doce pruebas unitarias, una por cada caso de TC-01 a TC-12. setUp crea estado_inicial para aislar cada caso. tests/test_api.py inicia un servidor HTTP local efímero y automatiza TC-03 y TC-05. El comando reproducible

es: $env:PYTHONPATH = "."; python -m unittest discover -s tests -v; Remove-Item Env:PYTHONPATH.

La ejecución previa a la corrección de auditoría registra 10 pruebas aprobadas en evidencias/integracion-api/02-regresion-suite. La regresión posterior registra 11 pruebas aprobadas en evidencias/tc-07-auditoria-segura-tdd/03-regresion-suite. La versión de Python usada en el laboratorio fue 3.14.6.

La ejecución final, con los doce casos completos, registra 14 pruebas aprobadas en evidencias/regresion-suite-final, repetida en dos corridas independientes (01-regresion-14-pruebas y 02-regresion-14-pruebas).

5. Ciclos rojo verde refactor y correcciones

Caso	Fallo rojo esperado	Corrección mínima verde	Refactor o regresión
TC-02	Esperado 403; inicial devolvía 200 a Ana sobre 202.	Comparación estudiante-propietario en leer_expediente.	Suite aprobada; evidencias/tc-02-acceso-horizontal-tdd.
TC-04	Esperado 401 tras revocar; inicial devolvía 200.	autenticar valida revocada y expirada.	Suite aprobada; evidencias/tc-04-sesion-revocada-tdd.
TC-03	Esperado 403 entre sedes; inicial devolvía 200.	actualizar_nota compara sede de docente y expediente.	Suite aprobada; evidencias/tc-03-modificacion-entre-sedes-tdd.
TC-07	La aserción de actor produjo KeyError; además auditoría exponía token.	registrar_auditoria registra actor/timestamp y no token.	Verde y regresión de 11; evidencias/tc-07-auditoria-segura-tdd.

6. Fase C Ejecución manual de API

Prueba manual	Procedimiento	Resultado observado	Captura saneada
TC-03	POST 202/nota, Bearer lab-maria, {"nota":85}.	403 Forbidden; Operación denegada.	manual-api-postman/01-tc03-postman-403.png
TC-05	POST 101/nota, Bearer lab-maria, {"nota":-1}.	400 Bad Request; Nota inválida.	manual-api-postman/02-tc05-postman-400.png

TC-04	POST /sesiones/revocar, luego GET 101 con misma sesión.	200 Sesión revocada y 401 No autenticado.	manual-api-postman/03 y 04.
PM-01	POST 101/nota con lab-maria y {"nota":"ochenta"}.	400 Bad Request; Nota inválida.	manual-api-postman/05-pm01-entrada-no-numerica-400.png

PM-01 es una comprobación manual adicional de entrada no numérica para SEC-04. No se llama TC-11: TC-11 conserva el diseño de frontera del valor válido 0. Esta decisión elimina una ambigüedad de identificación sin cambiar el catálogo.

7. Checklist de revisión estática

Área	Resultado	Tratamiento y verificación
Permisos	Conforme	Rol de estudiante, sede docente y restricción de administrador verificados por TC-01, 02, 03, 08 y 10.
Validación	Conforme	Tipo y rango verificados por TC-05, PM-01 y código de actualizar_nota.
Errores y exposición	Conforme en alcance	401/403/400 no incluyen nota; se verificó en aserciones y Postman.
Auditoría	Defecto confirmado y corregido	TC-07 obligó actor y timestamp y prohíbe token; verde y regresión aprobados.
T6	Limitación conocida	No hay rate limit; registrar como riesgo residual para dictamen Fase F.

8. Evidencias y transferencia

Las evidencias textuales y capturas saneadas se guardan en evidencias/: tc-01-expediente-propio, tc-02-acceso-horizontal-tdd, tc-03-modificacion-entre-sedes-tdd, tc-04-sesion-revocada-tdd, tc-05-nota-fuera-rango, tc-06-sesion-expirada, tc-07-auditoria-segura-tdd, tc-08-administrador-sin-modificacion, tc-09-docente-misma-sede, tc-11-limite-inferior-valido, tc-12-limite-superior-invalido, integracion-api, manual-api-postman y regresion-suite-final (dos corridas limpias). TC-10 permanece evidenciado dentro de la regresión global.

Fase D — Acta de inspección

Campo	Contenido
Revisor	Iván Barboza Blanco (no autor del código inspeccionado)
Autor del código y de las pruebas	Ian Angulo Matamoros
Fecha	30 de Octubre de 2026
Versión inspeccionada	Rama feat/ian-security-testing, código del laboratorio tal como quedó en el commit e319934
Objetos inspeccionados	Política de acceso completa (autenticar, leer_expediente, actualizar_nota y revocar_sesion en src/lab.py) y dos casos de prueba: TC-08 y TC-10
Método	Lectura estática contra la lista de comprobación de la unidad (identidades y permisos; datos y validación; errores, sesión y registros; prueba y mantenibilidad), con ejecución de cada hipótesis para confirmarla

Observaciones				
ID	**Observación**	**Objeto**	**Severidad**	**Acción**
D-01	leer_expediente() evalúa la existencia del expediente (404) antes de la autorización (403). Verificado: lab-ana sobre el expediente 999 recibe 404 y sobre 202 recibe 403. La diferencia permite a un	Política de acceso	Media	Pendiente: unificar la respuesta para no distinguir «no existe» de «no autorizado».

	estudiante deducir qué identificadores existen.			
D-02	actualizar_nota() valida con isinstance(nota, (int, float)) y en Python bool es subclase de int. Verificado: {"nota": true} responde 200 y guarda True como calificación. SEC-04 exige rechazar valores no numéricos con 400.	Política de acceso / validación	Media	Pendiente: excluir bool explícitamente en la validación de tipo.
D-03	revocar_sesion() consulta estado["sesiones"] sin pasar por autenticar(), por lo que SEC-03 no se aplica en esa ruta. Verificado: revocar con sesión expirada (lab-vencida) responde 200, y revocar una sesión ya revocada responde 200 otra vez, cuando SEC-03 exige 401.	Política de acceso	Media	Pendiente: aplicar autenticar() en la revocación, o documentar la idempotencia como excepción aprobada.
D-04	El objetivo de TC-08 dice que el administrador «puede leer expedientes de ambas sedes pero nunca modificar notas», pero la prueba solo verifica la segunda mitad. Verificado: el administrador lee 101 y 202 con 200, y ninguna prueba cubre esa lectura.	Caso de prueba TC-08	Baja	Pendiente: agregar la prueba de lectura del administrador, o acotar el objetivo documentado.
D-05	La bitácora solo registra operaciones exitosas. Verificado: tras dos intentos	Auditoría / SEC-06	Baja	Se acepta: queda como vacío del

	denegados y una revocación, estado["auditoria"] queda vacío. SEC-06 no lo exige, pero una bitácora solo de éxitos no permite detectar un abuso en curso.			requisito para una iteración posterior.
D-06	Las pruebas positivas (TC-10, y el mismo patrón en TC-01 y TC-11) verifican el diccionario devuelto, no el estado guardado. Las negativas (TC-03, TC-05, TC-08, TC-12) sí comprueban que la nota no cambió.	Casos TC-10, TC-01, TC-11	Baja	Pendiente: añadir una aserción sobre estado["expedientes"] en las pruebas positivas.

Aspectos conformes verificados

La revisión confirma que setUp() construye un estado independiente por prueba, así que la suite no depende del orden. Las pruebas de integración usan un puerto efímero y cierran el servidor en tearDown. log_message fue sobrescrito para no registrar el encabezado Authorization. El servidor escucha solo en 127.0.0.1, limita el cuerpo a 1024 bytes y responde con Cache-Control: no-store. Las respuestas de denegación contienen únicamente el campo error, sin nota ni datos del expediente. En actualizar_nota() la autorización se evalúa antes que la validación de entrada.

Conclusión de la inspección

Se registran seis observaciones verificables. Ninguna reabre los cinco defectos ya corregidos en las Fases B y C. Las tres de severidad media (D-01, D-02 y D-03) corresponden a rutas y condiciones que los 12 casos diseñados no cubrían, lo que confirma el valor de la inspección como complemento de la suite automatizada.

Fase E — Usabilidad y reproducibilidad

1. Ejecución de la suite siguiendo únicamente el README

El 30 de octubre de 2026, Iván Barboza Blanco (quien no escribió el código ni el README) descargó el repositorio en un equipo Windows distinto al de desarrollo y siguió los comandos del README raíz sin ayuda adicional.

Paso	Resultado	Observación
python -m unittest discover -s tests -v	**Falló:** «no se encontró Python; ejecutar sin argumentos para instalar desde el Microsoft Store…»	En Windows, python puede ser un alias vacío de la Microsoft Store. El README raíz no indica que Python deba estar instalado ni qué versión.
Instalación de Python 3.13 y reintento con python	**Falló** con el mismo mensaje	El alias de la Store seguía interceptando el comando.
py -m unittest discover -s tests -v	**Aprobó:** Ran 14 tests in 1.025s … OK	El lanzador py evita el alias. No estaba documentado.

Conclusión: Los pasos del README no fueron suficientes en este equipo. Una vez resuelto, el resultado coincide con las evidencias de Ian (14 pruebas, 0 fallos), lo que confirma la reproducibilidad en una máquina distinta. Dificultades: (1) el README raíz no declara el requisito de entorno (Python 3.10 o superior); (2) el comando python no es portable en Windows. Acción tomada: se añadió al README una nota de requisitos con la alternativa py.

2. Análisis de dos situaciones de usabilidad del control

Situación	Mensaje actual	Valoración
Sesión inválida (ausente, revocada o expirada)	HTTP 401 {"error": "No autenticado"}	Seguro: el mismo mensaje cubre los tres casos, así que no revela si un token existe, fue revocado o

		expiró. Mejorable: una persona legítima con sesión expirada no sabe qué hacer; no sugiere volver a iniciar sesión.
Acceso denegado	HTTP 403 {"error": "Acceso denegado"} (lectura) y {"error": "Operación denegada"} (escritura)	Seguro: el cuerpo contiene solo el campo error, sin nota, sede ni propietario del expediente (verificado con assertNotIn("nota", datos) y las capturas Postman). Mejorable: no indica el motivo ni la acción siguiente.

3. Ajustes de nombres y mensajes en dos pruebas

Prueba	Antes	Después	Motivo
TC-04	test_sesion_revocada_no_permita_lecturas, aserciones sin mensaje	test_rechaza_lectura_con_sesion_revocada, cada aserción con requisito y expectativa	El nombre anterior no declaraba la conducta con claridad; ahora la describe. Un fallo indica SEC-03/TC-04 sin abrir el código.
TC-06	test_rechaza_lectura_con_sesion_expirada, aserciones sin mensaje	test_rechaza_lectura_con_sesion_expirada, cada aserción con requisito y expectativa	Misma razón; el mensaje de fallo identifica la cuenta sintética (lab-vencida) y el expediente.

Fase F — Análisis de resultados y dictamen

Estado consolidado de los 12 casos

Caso	Estado final
TC-01	Aprobado
TC-02	Aprobado (defecto B-DEF-01 corregido)
TC-03	Aprobado (defecto B-DEF-03 corregido)
TC-04	Aprobado (defecto B-DEF-02 corregido)
TC-05	Aprobado (defecto B-DEF-04 corregido)
TC-06	Aprobado
TC-07	Aprobado (defecto C-DEF-01 corregido)
TC-08	Aprobado
TC-09	Aprobado
TC-10	Aprobado
TC-11	Aprobado
TC-12	Aprobado

De los 12 casos planificados, los 12 obtuvieron veredicto (ninguno quedó bloqueado o no ejecutado). No hubo fallos pendientes al cierre de la campaña: los 5 defectos detectados durante el ciclo TDD (B-DEF-01 a 04 y C-DEF-01) fueron corregidos

y verificados mediante regresión, ejecutada dos veces en estado limpio (ver evidencias/regresion-suite-final/).

Indicadores

- **Tasa de aprobación** = aprobados / (aprobados + fallidos) × 100 = 12 / 12 × 100 = 100 %
- **Avance** = (aprobados + fallidos) / planificados × 100 = 12 / 12 × 100 = 100 %
- **Cobertura de requisitos** = requisitos con al menos una prueba válida / requisitos definidos × 100 = 7 / 7 × 100 = 100 % (SEC-01 a SEC-07, cada uno con al menos un caso asociado; ver matriz_trazabilidad.csv)

Esta tasa de 100 % refleja el estado final después de corregir los 5 defectos encontrados durante el proceso TDD; no significa que el sistema nunca falló, sino que todos los fallos detectados fueron tratados y re-verificados. El riesgo residual T6 (sin límite de intentos de token) queda fuera de esta cobertura porque no corresponde a un requisito SEC definido en Fase A; se trata como limitación en el punto de decisión de liberación.

La cobertura de requisitos del 100 % mide que cada SEC tenga al menos un caso, no que los casos agoten el requisito: la inspección de Fase D mostró que SEC-04 admite un valor booleano como nota (D-02) y que SEC-03 no se aplica en la ruta de revocación (D-03), situaciones que ningún caso de los 12 cubría.

Registro de hallazgos

Se confirmaron 5 hallazgos durante la campaña, todos reales (defectos del producto, no fallos de la propia prueba) y todos corregidos y verificados por regresión. No se registraron falsos positivos ni resultados no concluyentes.

ID	Requisito	Pasos de reproducción	Esperado	Observado (antes de corregir)	Impacto	Corrección	Evidencia

H-01	SEC-01	GET /expedientes/202 con Bearer lab-ana (Ana intenta leer el expediente de Luis).	403, sin datos de Luis.	200; el expediente ajeno se exponía completo.	Alto — cualquier estudiante podía ver notas y datos de otro cambiando el identificador en la URL.	Se agregó comparación explícita estudiante-propietario en leer_expediente().	evidencias/tc-02-acceso-horizontal-tdd/
H-02	SEC-03	Revocar sesión lab-ana; luego GET /expedientes/101 con el mismo token.	401 tras revocar.	200; la sesión revocada seguía dando acceso.	Alto — una sesión revocada por seguridad seguía siendo válida indefinidamente.	autenticar() valida explícitamente el estado de revocación.	evidencias/tc-04-sesion-revocada-tdd/, manual-api-postman/03-04
H-03	SEC-02	POST /expedientes/202/nota {“nota”:85} con Bearer	403, nota se mantiene en 91.	200; la nota se modificó indebidamente.	Alto — un docente podía alterar	actualizar_nota() compara la sede del docente	evidencias/tc-03-modificacion-entre-sedes-tdd/, manual-api-postman/01

		lab-maria (docente de Central) sobre expediente de Pacífico.			calificaciones de estudiantes de otra sede.	contra la del expediente.	
H-04	SEC-04	POST /expedientes/101/nota {“nota”:-1} con Bearer lab-maria.	400, nota se mantiene en 82.	200; se aceptó el valor fuera de rango.	Medio — datos académicos inválidos podían persistirse.	actualizar_nota() valida tipo y rango 0-100.	evidencias/tc-05-nota-fuera-rango/, manual-api-postman/02
H-05	SEC-06	Leer expediente 101 (acción autorizada); inspeccionar la última entrada de la bitácora.	Entrada con actor y timestamp, sin token.	Error al faltar el actor; además el token se guardaba en texto claro.	Alto — exposición de credenciales de sesión en los logs, riesgo de secuestro de sesión.	registrar_auditoria() registra actor/timestamp y deja de guardar el token.	evidencias/tc-07-auditoria-segura-tdd/

Riesgo residual (no es un hallazgo a corregir dentro del alcance): T6; no existe límite de intentos de autenticación con token, lo que permitiría intentos repetidos sin bloqueo. Se documenta como limitación conocida, no como defecto introducido por el equipo.

Decisión de liberación y limitaciones

Defectos abiertos: Ninguno de los 12 casos planificados quedó con fallo pendiente. La inspección de Fase D dejó abiertas tres observaciones de severidad media, sin corregir al cierre de la campaña: D-01 (el código 404 frente a 403 revela qué expedientes existen), D-02 (un booleano se acepta como nota válida) y D-03 (la revocación de sesión no valida el estado de la sesión). Ninguna permite leer o modificar datos de otra persona, por lo que no constituyen fallos críticos de autorización.

Decisión: *Liberar con condiciones.* Los 5 defectos confirmados (3 de severidad alta: acceso horizontal, sesión revocada e integridad entre sedes) fueron corregidos y verificados mediante regresión en dos ejecuciones limpias. No se encontró ningún fallo crítico de autorización abierto al momento de esta decisión. Como advierte el propio enunciado, una tasa de aprobación alta no autoriza por sí sola la liberación — en este caso la decisión se apoya en que los defectos de mayor severidad fueron efectivamente cerrados y verificados, no solo en el porcentaje.

Condición de la liberación: Corregir D-01, D-02 y D-03, y atender el riesgo residual T6 (sin límite de intentos de token), antes de cualquier uso con datos reales. No bloquean la liberación del laboratorio en su alcance académico.

Limitaciones del estudio: La campaña se limitó a los 12 casos definidos sobre un laboratorio local con datos sintéticos; no se ejecutaron herramientas SAST/DAST automatizadas adicionales a la revisión estática manual. La inspección (Fase D) y la ejecución con el README (Fase E) las realizó Iván Barboza Blanco, distinto del autor del código, pero ambos son integrantes del mismo equipo: no hubo revisión de un tercero ajeno. Los hallazgos D-01 a D-03 se verificaron por ejecución, no solo por lectura.

Responsable de la decisión hipotética: El equipo (Iván Barboza Blanco e Ian Angulo Matamoros), bajo revisión del docente como entidad evaluadora del laboratorio.

Anexos

Anexo A Scripts detallados de los casos de prueba

Este anexo incorpora la estructura narrativa de cada caso sin sustituir las secciones anteriores del documento. Los resultados y estados actualizados permanecen también en el Registro de gestión QA por caso.

TC-01 — Lectura del expediente propio por estudiante

Identificación	TC-01 / SEC-01 / amenaza T1 / prioridad alta.
Objetivo	Confirmar que un estudiante autenticado puede leer únicamente su propio expediente.
Precondiciones	Estado inicial; token lab-ana válido; el expediente 101 pertenece a Ana.
Datos / pasos	GET /expedientes/101 con encabezado Authorization: Bearer lab-ana.
Oráculo	Código 200; la respuesta incluye los datos y la nota propios de Ana; el estado no cambia.
Observado	200; datos de Ana devueltos correctamente. Prueba unitaria test_estudiante_consulta_expediente_propio, incluida también en la regresión final de 14 pruebas. Evidencia: evidencias/tc-01-expediente-propio/01-ejecucion-tc01.
Resultado	Aprobado. Sin defecto.

TC-02 — Acceso horizontal indebido de estudiante

Identificación	TC-02 / SEC-01 / amenaza T1 / prioridad alta.

Objetivo	Verificar que un estudiante no puede leer el expediente de otra persona.
Precondiciones	Estado inicial; token lab-ana válido; el expediente 202 pertenece a Luis.
Datos / pasos	GET /expedientes/202 con Authorization: Bearer lab-ana.
Oráculo	Código 403; la respuesta no debe incluir la nota ni ningún dato de Luis; el expediente 202 permanece sin cambios.
Observado	Rojo: el servicio devolvía 200 y exponía el expediente ajeno (defecto B-DEF-01). Verde/refactor: 403 sin datos de Luis, suite completa aprobada tras el fix. Evidencia: evidencias/tc-02-acceso-horizontal-tdd/ (ciclo rojo-verde-refactor completo).
Resultado	Aprobado. Defecto B-DEF-01 corregido.

TC-03 — Modificación entre sedes por docente

Identificación	TC-03 / SEC-02 / amenaza T2 / prioridad alta.
Objetivo	Verificar que un docente no puede modificar la nota de un expediente de otra sede.
Precondiciones	Estado inicial; token lab-maria (sede Central) válido; el expediente 202 es de Pacífico con nota 91.
Datos / pasos	POST /expedientes/202/nota con {"nota":85} y Authorization: Bearer lab-maria.

Oráculo	Código 403; la nota del expediente 202 debe permanecer en 91.
Observado	Rojo: el servicio aceptaba el cambio (200), defecto B-DEF-03. Verde/refactor: 403 y nota intacta en 91. Confirmado por prueba unitaria, prueba de integración HTTP y Postman. Evidencia: evidencias/tc-03-modificacion-entre-sedes-tdd/, evidencias/integracion-api/, evidencias/manual-api-postman/01-tc03-postman-403.png.
Resultado	Aprobado. Defecto B-DEF-03 corregido.

TC-04 — Lectura con sesión revocada

Identificación	TC-04 / SEC-03 / amenaza T3 / prioridad alta.
Objetivo	Verificar que una sesión revocada no permite leer expedientes.
Precondiciones	Estado inicial; token lab-ana válido; expediente 101 disponible.
Datos / pasos	POST /sesiones/revocar con Bearer lab-ana; luego GET /expedientes/101 con el mismo token.
Oráculo	La revocación responde 200; la lectura posterior con el mismo token responde 401 sin datos del expediente.
Observado	Rojo: la sesión revocada seguía aceptando lecturas (200), defecto B-DEF-02. Verde/refactor: 200 al revocar y 401 en la lectura posterior, sin datos. Confirmado también por Postman (revocación y lectura denegada). Evidencia: evidencias/tc-04-sesion-revocada-tdd/, evidencias/manual-api-postman/03-tc04-revocacion-200.png y 04-tc04-lectura-401.png.

Resultado	Aprobado. Defecto B-DEF-02 corregido.

TC-05 — Límite inferior inválido de nota

Identificación	TC-05 / SEC-04 y SEC-05 / amenaza T4 / prioridad media.
Objetivo	Verificar que el sistema rechaza una nota por debajo del rango permitido (0-100).
Precondiciones	Estado inicial; token lab-maria válido; expediente 101 con nota 82.
Datos / pasos	POST /expedientes/101/nota con {"nota":-1} y Authorization: Bearer lab-maria.
Oráculo	Código 400; la nota del expediente 101 debe permanecer en 82.
Observado	Rojo: el servicio aceptaba el valor -1 (200), defecto B-DEF-04. Verde/refactor: 400 y nota intacta en 82. Confirmado por prueba unitaria, integración HTTP y Postman. Evidencia: evidencias/tc-05-nota-fuera-rango/, evidencias/integracion-api/, evidencias/manual-api-postman/02-tc05-postman-400.png.
Resultado	Aprobado. Defecto B-DEF-04 corregido.

TC-06 — Lectura con sesión expirada

Identificación	TC-06 / SEC-03 / amenaza T3 / prioridad alta.
Objetivo	Verificar que una sesión expirada (lab-vencida) no permite leer expedientes.

Precondiciones	Estado inicial; sesión lab-vencida marcada como expirada; expediente 101 disponible.
Datos / pasos	GET /expedientes/101 con Authorization: Bearer lab-vencida.
Oráculo	Código 401; sin datos del expediente en la respuesta.
Observado	401 correctamente, sin datos devueltos. Prueba unitaria test_sesion_expirada_no_permita_lecturas. Evidencia: evidencias/tc-06-sesion-expirada/ejecucion-tc06.
Resultado	Aprobado. Sin defecto.

TC-07 — Auditoría sin exposición de token

Identificación	TC-07 / SEC-06 / amenaza T5 / prioridad media.
Objetivo	Verificar que la bitácora de auditoría registra actor y marca de tiempo sin exponer el token de sesión.
Precondiciones	Estado inicial; una lectura autorizada ya ejecutada sobre el expediente 101; acceso de prueba a la bitácora.
Datos / pasos	Leer el expediente 101; inspeccionar la última entrada registrada en la bitácora de auditoría.
Oráculo	La entrada debe incluir actor, acción, id de expediente y marca de tiempo; no debe incluir el token de sesión.
Observado	Rojo: la prueba fallaba con KeyError: 'actor' porque la auditoría no registraba el actor y sí guardaba el token en texto claro (defecto C-DEF-01). Verde/refactor: la entrada registra actor y timestamp

	sin token; regresión de 11 pruebas aprobada tras el fix. Evidencia: evidencias/tc-07-auditoria-segura-tdd/.
Resultado	Aprobado. Defecto C-DEF-01 corregido.

TC-08 — Modificación denegada para administrador

Identificación	TC-08 / SEC-07 / control de autorización por rol / prioridad alta.
Objetivo	Verificar que un administrador puede leer expedientes de ambas sedes pero nunca modificar notas.
Precondiciones	Estado inicial; token lab-admin válido; expediente 101 con nota 82.
Datos / pasos	POST /expedientes/101/nota con {"nota":90} y Authorization: Bearer lab-admin.
Oráculo	Código 403; la nota debe permanecer en 82.
Observado	403 correctamente, nota intacta en 82. El control ya estaba implementado de forma correcta en el código original; no se encontró defecto. Evidencia: evidencias/tc-08-administrador-sin-modificacion/.
Resultado	Aprobado. Sin defecto.

TC-09 — Lectura autorizada por docente de su sede

Identificación	TC-09 / SEC-02 / control de autorización por sede / prioridad alta.

Objetivo	Confirmar que un docente puede leer expedientes de su propia sede.
Precondiciones	Estado inicial; token lab-maria (Central) válido; expediente 101 es de Central.
Datos / pasos	GET /expedientes/101 con Authorization: Bearer lab-maria.
Oráculo	Código 200; lectura autorizada por coincidencia de sede.
Observado	200 correctamente. Prueba unitaria test_docente_consulta_expediente_de_su_sede, incluida también en la regresión final de 14 pruebas. Evidencia: evidencias/tc-09-docente-misma-sede/01-ejecucion-tc09.
Resultado	Aprobado. Sin defecto.

TC-10 — Actualización autorizada por docente de su sede

Identificación	TC-10 / SEC-02 y SEC-05 / autorización e integridad por sede / prioridad alta.
Objetivo	Verificar que un docente puede actualizar la nota de un expediente de su propia sede.
Precondiciones	Estado inicial; token lab-maria válido; expediente 101 (Central) con nota 82.
Datos / pasos	POST /expedientes/101/nota con {"nota":85} y Authorization: Bearer lab-maria.

Oráculo	Código 200; nota 85 persistida; el resto de expedientes permanece sin cambios.
Observado	200 correctamente, nota actualizada a 85. Prueba unitaria test_docente_actualiza_nota_en_su_sede. Sin carpeta de evidencia individual: queda registrada dentro de la regresión global (evidencias/regresion-suite-final/) por no haber requerido corrección.
Resultado	Aprobado. Sin defecto.

TC-11 — Límite inferior válido de nota

Identificación	TC-11 / SEC-04 / validación de frontera / prioridad media.
Objetivo	Confirmar que el valor límite 0 sí se acepta como nota válida.
Precondiciones	Estado inicial; token lab-maria válido; expediente 101 de Central.
Datos / pasos	POST /expedientes/101/nota con {"nota":0} y Authorization: Bearer lab-maria.
Oráculo	Código 200; nota 0 persistida.
Observado	200 correctamente, nota 0 persistida. Prueba unitaria test_acepta_nota_en_limite_inferior_valido, incluida también en la regresión final de 14 pruebas. Evidencia: evidencias/tc-11-limite-inferior-valido/01-ejecucion-tc11.
Resultado	Aprobado. Sin defecto.

TC-12 — Límite superior inválido de nota

Identificación	TC-12 / SEC-04 y SEC-05 / amenaza T4, validación de frontera / prioridad media.
Objetivo	Verificar que el sistema rechaza una nota por encima del rango permitido (101).
Precondiciones	Estado inicial; token lab-maria válido; expediente 101 con nota 82.
Datos / pasos	POST /expedientes/101/nota con {"nota":101} y Authorization: Bearer lab-maria.
Oráculo	Código 400; la nota debe permanecer en 82.
Observado	400 correctamente, nota intacta en 82. Prueba unitaria test_rechaza_nota_en_limite_superior_invalido, incluida también en la regresión final de 14 pruebas. Evidencia: evidencias/tc-12-limite-superior-invalido/01-ejecucion-tc12.
Resultado	Aprobado. Sin defecto.

Comandos, versión y resultados de ejecución final

Entorno: Python 3.14.6; Windows PowerShell; estado limpio por setUp y estado_inicial().

Comando de regresión: $env:PYTHONPATH = "."; python -m unittest discover -s tests -v; Remove-Item Env:PYTHONPATH.

Resultado: dos ejecuciones limpias y las ejecuciones aisladas de TC-09, TC-11 y TC-12 finalizaron correctamente. La suite final ejecutó 14 pruebas: 12 unitarias y 2 de integración HTTP, sin fallos. Evidencias: evidencias/tc-09-docente-misma-sede, tc-11-limite-inferior-valido, tc-12-limite-superior-invalido y regresion-suite-final.

Anexo B — Evidencias de las Fases D y E

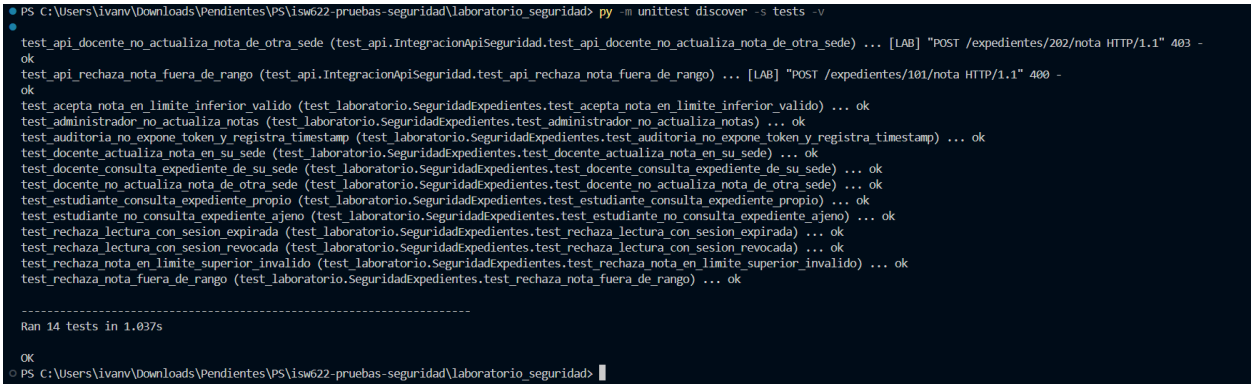


Figura B-1. *Suite completa ejecutada con py: Ran 14 tests … OK. Incluye los dos tests renombrados. Fase E, puntos 1 y 3.*

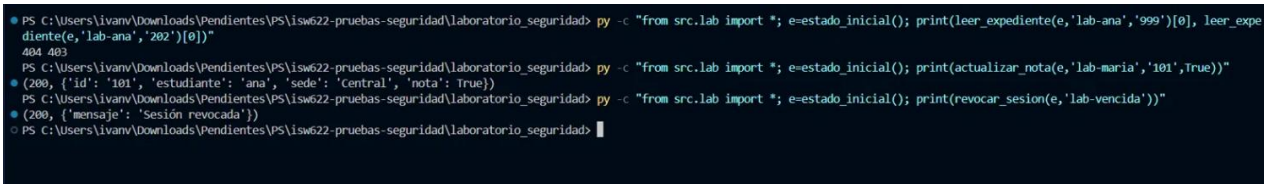


Figura B-2. *Verificación por ejecución de D-01 (404 frente a 403), D-02 (nota True aceptada con 200) y D-03 (revocación de sesión expirada con 200). Fase D.*

Uso de Inteligencia Artificial:

Se utilizaron asistentes de IA para consultar documentación y elaborar propuestas de redacción y de pruebas. El equipo ejecutó la suite, reprodujo las observaciones de la inspección y verificó las evidencias de forma independiente antes de incorporarlas al informe.